Confidential Radiology AI

Attestation-Gated Chest X-ray Inference on IBM Secure Execution

Team **Revolution** | IBM Z Datathon 2026 | Theme: AI Secured

Anish Mall (Team Leader)
anishmall3879@gmail.com

Sourav Kumar
oyesourav05012006@gmail.com

Aashi Soni
aashi2701soni@gmail.com

Ayush Kesarwani
ayushkesharwani64@gmail.com

Abstract

Hospitals want AI to read chest X-rays, but the usual way of running a model means decrypting the image in ordinary server memory. At that moment a hypervisor administrator, a compromised host or a simple memory dump can reach the patient's data. We propose *Confidential Radiology AI*, a pipeline where each study stays AES-256-GCM encrypted on disk and on the network, and is decrypted only inside an IBM Secure Execution guest on LinuxONE. A key broker hands over the study key only if the guest image and the model file match hashes the hospital has approved. Inside the guest, a ResNet-50 scores the image and returns a deliberately small answer: a probability, a model hash and an attestation measurement. No pixels, heatmaps or free-text reports leave the boundary. We tried fully homomorphic encryption first and set it aside as the main path, because published full forward passes take tens of seconds to minutes against milliseconds in the clear. We keep it as a comparison, not as the product. This is a research prototype and is not intended for clinical use.

Keywords: confidential computing, IBM Secure Execution, LinuxONE, medical imaging, attestation, homomorphic encryption.

1. The problem we picked

A chest radiograph is protected health information in its own right: the pixels can carry burned-in text, and the DICOM header carries names, record numbers and dates. Regulations such as HIPAA and GDPR expect encryption and tight access control, yet almost every inference service still decrypts the image in plain RAM before the model touches it. Anonymising the header does not fix this, because pixels can still identify a patient. Sending studies to a vendor cloud under a contract moves the trust problem rather than solving it. Training only on local data leaves each hospital with a small, weaker model.

We set three goals that must hold together. The score must equal what the same model gives on the clear image, up to floating-point error. The study must be unreadable outside a defined trust boundary, including to root on the host. And the hospital must be able to check, before any key is released, that the code about to see the image is the code it approved.

2. What we tried first, and why we moved on

Fully homomorphic encryption (CKKS) lets a server compute on ciphertext, so in principle nobody on the server ever sees the image. We read the numbers carefully before committing. CKKS only offers addition and multiplication, so ReLU and max-pooling have to be replaced by polynomial approximations, and noise management adds expensive bootstrapping. Kim et al. report 92,142 ms per chest X-ray in a compressed latent space against 8.39 ms in the clear [2], and a direct CKKS CNN on 28×28 PneumoniaMNIST images averages about 88 s [3]. Ciphertext expansion also pushes memory use into the hundreds of gigabytes for larger networks. A radiology workflow cannot wait that long.

Option	Where the image is plaintext	Reported cost	Our role
Plain inference	Ordinary server memory	Tens of ms (CPU)	Baseline
CKKS (HE)	Nowhere on the server	88–92 s per image	Comparison
Secure Execution	Only inside the guest	Near baseline (to be measured)	**Product**

Table 1. Three ways to run the same classifier. HE figures come from the cited papers, not our own runs.

HE gives the stronger guarantee, since it needs no trust in hardware. On a hospital-owned machine, though, the party we most need to exclude is the person administering the host, and a hardware boundary does that at interactive speed.

3. Our approach

IBM Secure Execution for Linux lets an ultravisor decrypt and integrity-check a guest image, mark its memory as secure, and keep it away from KVM and the operator [1]. We build the pipeline around that boundary (Figure 1).

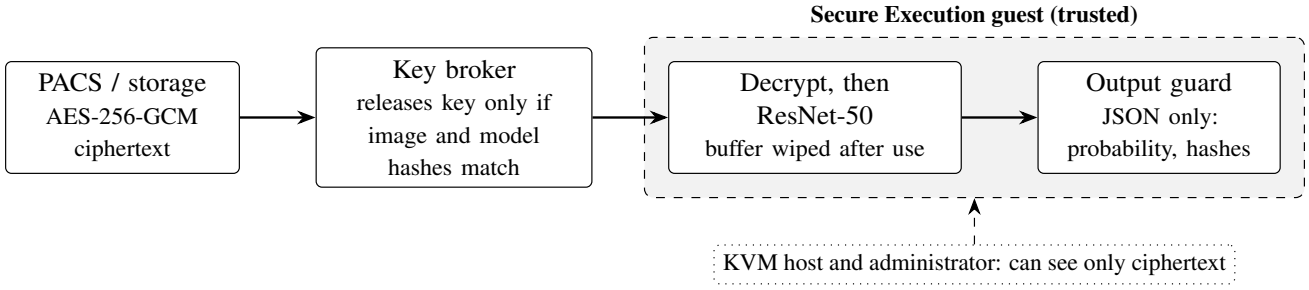


Figure 1. Study flow. The host is untrusted; only the measured guest sees pixels.

1. **Envelope encryption.** Each study gets its own data key and is stored as nonce, ciphertext and tag. The data key is wrapped by a key held in a Crypto Express hardware security module.
2. **Measured boot.** The guest image is encrypted to the target machine's host key document, so only that machine can start it. Attestation (`pvattest`) or a Hyper Protect contract confirms what is running.
3. **Fail-closed key release.** If the guest measurement or the model hash is not on the allowlist, no key is released and the study stays ciphertext.
4. **Minimal output.** The guard returns a fixed JSON schema and nothing else. We treat a Grad-CAM overlay as the radiograph itself, so it never leaves the guest.

4. How it maps to IBM Z

At rest we use dm-crypt with AES through CPACF. In flight we use TLS, with hardware crypto offload. In use, Secure Execution protects the guest, and on z16 and later, secure guests can use Crypto Express domains after attestation. Orchestration can go through Confidential Containers on Kubernetes (s390x). For inference we start on the CPU with PyTorch or ONNX Runtime, which always works. Then we compile the ONNX model with the IBM Z Deep Learning Compiler for the Telum accelerator and report how many operators actually run there. We use ResNet-50 rather than DenseNet-121 because residual additions suit the accelerator better than concatenations. Spyre is not needed for a classifier of this size, so we only mention it as a path to a future report-drafting model.

5. Build plan and evaluation

Task and data. One task: probability of lung opacity or pneumonia on a frontal chest radiograph, using pretrained TorchXRayVision weights [4] and the radiologist-labelled RSNA Pneumonia dataset [5], with a patient-level split. We avoid the text-mined NIH 14-label setup and unvetted COVID collections, which carry known label and duplication problems.

What we will measure.

- *Utility:* AUC, sensitivity and specificity at one fixed threshold, and calibration, on the clear model. For prior art, TorchXRayVision reports roughly 0.85–0.87 AUC on this label set.
- *Parity:* the maximum difference between the clear and secure-path probabilities. It should be floating-point noise, far below 10^{-4}. A gap of several percent would mean a bug.
- *Security tests:* wrong measurement, wrong model hash, truncated ciphertext and flipped tag must all refuse; a process outside the guest must recover only ciphertext; the response must contain nothing but the schema.
- *Latency:* median and p95 for the clear and secure paths on the same machine, batch size one.

If Secure Execution hardware is not available during the event, we will run the same policy on x86 and label every screen as a *measurement-gated enclave simulation*, since a simulation cannot prove that host root is excluded.

6. Limits we state up front

The inference code inside the guest is trusted, so we keep the image minimal, block outbound connections and check every response. Secure Execution is not a proof against every side channel. The model is trained on US adult frontal films and may behave differently on other detectors or on children. Fairness gaps are documented for chest X-ray models [6], and we report subgroup results only if the metadata allows. Encryption does not make this prototype HIPAA-compliant or a medical device. It demonstrates the technical safeguards, and we do not claim sub-millisecond Telum latency for an X-ray network, since IBM's published figures come from small fraud-detection models.

References

[1] IBM, *Linux on IBM Z and LinuxONE: IBM Secure Execution for Linux*, 2024. ibm.com/docs (Linux on IBM Z and LinuxONE).
[2] Kim, Jo, Ra, Park, Privacy-preserving chest X-ray classification in latent space, arXiv:2506.15258.
[3] SBSeg, Privacy-preserving ML with homomorphic encryption: a benchmark for medical image analysis (PneumoniaMNIST).
[4] Cohen et al., TorchXRayVision, arXiv:2111.00595.
[5] Shih et al., RSNA Pneumonia Detection Challenge, *Radiology: Artificial Intelligence*, 2019.
[6] Seyyed-Kalantari et al., Underdiagnosis bias of AI in chest X-ray models, *Nature Medicine*, 2021.